v0.52 — Document upload security

Release decision: NO-GO · 11 November 2026 · Offline development checkpoint

Executive summary

This milestone adds mandatory ClamAV malware screening to the authenticated document upload path. Files are checked in memory before encrypted storage and document metadata insertion. Only an explicit clean scanner verdict allows a write; threats, outages, malformed responses, socket failures and timeouts block the upload.

This is a security improvement, not a production approval. No genuine npm lockfile, installed project dependencies, live ClamAV daemon, disposable PostgreSQL database or complete Git history were available in this execution environment.

Controls implemented

Control	Engineering behavior
Trusted scan boundary	Application-scoped scanner interface and ClamAV INSTREAM adapter; files scanned as exact in-memory bytes.
Upload decision	CLEAN only = write; INFECTED = generic HTTP 400; unavailable/unknown/timeouts = generic HTTP 503.
Network containment	Production requires an absolute private Unix socket. Loopback TCP is permitted only for development/CI.
Existing safeguards preserved	5 MiB cap, allowed MIME/signature checks, role and tenant authorization, AES-GCM blob encryption, audit and RLS.
Release gates	13 new tests; real clean/EICAR ClamAV self-test wired into CI and supervised Kali validation.

Evidence boundaries

The protocol tests used a simulated local Unix-socket ClamAV responder. They verify bytes and error handling but do not validate the live antivirus engine or current signatures. The separate real-daemon test was attempted and failed because no scanner was configured here.

Verification and release blockers

Check	Observed result
New malware-scanner tests	13 / 13 PASS (offline protocol and service integration tests)
Historical/version checks	50 / 50 PASS (v0.03–v0.52; multiple batches)
Architecture and syntax	3 / 3 architecture PASS; 104 TS/TSX source files syntax-scanned
CI and migration integrity	Static CI contract PASS; 25 / 25 migration hashes unchanged
Source secret scanner	2,079 source files; 0 high-confidence matches (snapshot only)
Real ClamAV self-test	BLOCKED — no configured daemon or signatures
Dependency and build verification	BLOCKED/FAILED — genuine npm lockfile and dependencies missing
Release prerequisite preflight	BLOCKED — 3 / 11 prerequisites present
Live database, browser and HTTPS	NOT RUN in this environment

Mandatory next actions

• Configure isolated ClamAV with updated signatures on Kali/staging. Prove clean fixture acceptance, EICAR rejection, scanner outage denial, permissions and no partial persistent writes.

• Generate and review an authentic npm lockfile, run npm ci, npm audit, complete API/web builds, tests, and independent secrets/history scans; remediate critical/high findings.

• Apply and validate existing PostgreSQL migrations only in a restored disposable database; test RLS A/B tenant isolation, server roles, MFA and recipient workflows across live API instances.

• Verify HTTPS, cookies and CSRF, SSH/firewalls, payload limits and storage quotas, admin permissions, price authority, backup restoration and security incident response.

• Run independent security testing and obtain an explicit release decision before processing customer asset documents or charging clients.

Verdict: The v0.52 upload security change is implemented and offline tested. Live scanning efficacy and production safety remain unverified. Release is NO-GO.